

Article (13) Technology Risk and Information Security

C 15/2021 Effective from 6/6/2021

Status: In-Force

1. Payment Service Providers shall comply with this Article (13) and are encouraged to consult [Annex II](#) for the Guidance on the best practices for technology risk and information security.

Technology Risk

2. Payment Service Providers are expected to take into account international best practices and standards when designing and implementing the technology and specific risk management systems and processes.
3. A Payment Service Provider shall establish an effective technology and cyber security risk management framework to ensure the adequacy of IT controls, cyber resilience, the quality and security, including the reliability, robustness, stability and availability, of its computer systems, and the safety and efficiency of the operations of Retail Payment Services. The framework shall be "fit for purpose" and commensurate with the risks associated with the nature, size, complexity and types of business and operations, the technologies adopted and the overall risk management system of the Payment Service Provider. Consideration shall be given to adopting recognized international standards and practices when formulating such risk management framework.
4. A Payment Service Provider's effective technology risk management framework shall comprise proper IT governance, a continuous technology risk management process and implementation of sound IT control practices.
5. A Payment Service Provider shall establish a general framework for management of major technology-related projects, such as in-house software development and acquisition of information systems. This framework shall specify, among other things, the project management methodology to be adopted and applied to these projects.
6. Payment Service Provider shall apply and meet at a minimum the UAE Information Assurance Standards, as may be amended from time to time.

IT Governance

7. A Payment Service Provider shall establish a proper IT governance framework. IT governance shall cover various aspects, including a clear structure of IT functions and the establishment of IT control policies. While there could be different constructs, the major functions shall include an effective IT function, a robust technology risk management function, and an

independent technology audit function.

8. The Board, or a committee designated by the Board shall be responsible for ensuring that a sound and robust risk management framework is established and maintained to manage technology risks in a manner that is commensurate with the risks posed by the Payment Service Provider's Retail Payment Activities.

Security Requirements

9. A Payment Service Provider must define clearly its security requirements in the early stage of system development or acquisition as part of business requirements and adequately built during the system development stage.
10. A Payment Service Provider using the Agile methods to accelerate software development must incorporate adequate security practices to ensure the software is not compromised at any stage in its development process.
11. A Payment Service Provider that develops an Application Programming Interface (API) or provides an API shall establish safeguards to manage the development and provision of the APIs to secure the interaction and exchange of data between various software applications.

Network and Infrastructure Management

12. A Payment Service Provider whose monthly average value of Payment Transactions amounts to ten (10) million Dirhams or above shall clearly assign overall responsibility for network management to individuals who are equipped with expertise to fulfil their duties. Network standards, design, diagrams and operating procedures shall be formally documented, kept up-to-date, communicated to all relevant network staff and reviewed periodically.
13. A Payment Service Provider shall establish a security administration function and a set of formal procedures for administering the allocation of access rights to system resources and application systems, and monitoring the use of system resources to detect any unusual or unauthorized activities.
14. Payment Service Providers shall exercise due care when controlling the use of and access to privileged and emergency IDs. The necessary control procedures include:
 - 14.1. changing the default password;
 - 14.2. implement strong password control, with minimum password length and history, password complexity as well as maximum validity period;
 - 14.3. restricting the number of privileged users;

- 14.4. implementing strong controls over remote access by privileged users;
- 14.5. granting of authorities that are strictly necessary to privileged and emergency IDs;
- 14.6. formal approval by appropriate senior personnel prior to being released for usage;
- 14.7. logging, preserving and monitoring of the activities performed by privileged and emergency IDs (e.g. peer reviews of activity logs);
- 14.8. prohibiting sharing of privileged accounts;
- 14.9. proper safeguard of privileged and emergency IDs and passwords (e.g. kept in a sealed envelope and locked up inside the data center); and
- 14.10. changing of privileged and emergency IDs' passwords immediately upon return by the requesters.

Cyber Security Risk

- 15. Where a Payment Service Provider is heavily reliant on Internet and mobile technologies to deliver the Retail Payment Services it provides, cyber security risks shall be adequately managed through the Payment Service Provider's technology risk management process. The Payment Service Provider shall also commit adequate skilled resources to ensure its capability to identify the risk, protect its critical services against the attack, contain the impact of cyber security incidents and restore the services.
- 16. A Payment Service Provider shall establish a cyber incident response and management plan to swiftly isolate and neutralize a cyber threat and to resume affected services as soon as possible. The plan shall describe procedures to respond to plausible cyber threat scenarios
- 17. Payment Service Providers whose monthly average value of Payment Transactions amounts to ten (10) million Dirhams or above shall regularly assess the necessity to perform penetration and cyber-attack simulation testing. Coverage and scope of testing shall be based on the cyber security risk profile, cyber intelligence information available, covering not only networks (both external and internal) and application systems but also social engineering and emerging cyber threats. A Payment Service Provider shall also take appropriate actions to mitigate the issues, threats and vulnerabilities identified in penetration and cyber-attack simulation testing in a timely manner, based on the impact and risk exposure analysis.

Retail Payment Service User Authentication

- 18. A Payment Service Provider shall select and implement reliable and effective authentication techniques to validate the identity and authority of its Retail Payment Service Users. Multi-

factor authentication shall be required for high-risk transactions.

19. End-to-end encryption shall be implemented for the transmission of Retail Payment Service User passwords so that they are not exposed at any intermediate nodes between the Retail Payment Service User mobile application or browser and the system where passwords are verified.

Login Attempts and Session Management

20. A Payment Service Provider shall implement effective controls to limit the number of login or authentication attempts (e.g. wrong password entries), implementing time-out controls and setting time limits for the validity of authentication. If one-time password is used for authentication purpose, a Payment Service Provider shall ensure that the validity period of such passwords is limited to the strict minimum necessary.
21. A Payment Service Provider shall have processes in place ensuring that all Payment Transactions are logged with an appropriate audit trail.

Administration of Retail Payment Service User Accounts

22. Where a Payment Service Provider providing Payment Account Issuance Services allows a Retail Payment Service User to open a Payment Account through an online channel, a reliable method shall be adopted to authenticate the identity of that Retail Payment Service User. In general, the electronic know your customer (i.e. Retail Payment Service User) (eKYC) processes accepted by the Central Bank for Banks is acceptable for the customer verification and validation processes of Payment Account Issuance Services.
23. A Payment Service Provider shall perform adequate identity checks when any Retail Payment Service User requests a change to the Retail Payment Service User's Payment Account information or contact details that are useful for the Retail Payment Service User to receive important information or monitor the activities of the Retail Payment Service User's Payment Accounts.
24. A Payment Service Provider shall implement effective controls such as two-factor authentication, to re-authenticate the Retail Payment Service User before effecting each high-risk transaction. High-risk transactions shall, at least, include:
 - 24.1. Payment Transactions that exceeded the predefined transaction limit(s);
 - 24.2. Change of personal contact details; and
 - 24.3. Unless it is not practicable to implement, Payment Transactions that exceeded the aggregate rolling limit(s) (i.e. total value of Payment Transactions over a period of time).

Business Continuity

25. A Payment Service Provider shall have in place an adequate business continuity management program to ensure continuation, timely recovery, or in extreme situations orderly scaledown of critical operations in the event of major disruptions caused by different contingent scenarios. An adequate business continuity management program comprises business impact analysis, recovery strategies, a business continuity plan and alternative sites for business and IT recovery.
26. A Payment Service Provider shall put in place a set of recovery strategies to ensure that all critical business functions identified in a business impact analysis can be recovered in accordance with the predefined recovery timeframe. These recovery strategies shall be clearly documented, thoroughly tested and regularly reviewed to ensure achievement of recovery targets.
27. A Payment Service Provider shall put in place effective measures to ensure that all business records, in particular Retail Payment Service User records, can be timely restored in case they are lost, damaged, or destroyed. A Payment Service Provider shall also allow Retail Payment Service Users to access their own records in a timely manner. A Payment Service Provider shall notify Retail Payment Service Users of any loss in their records through an operational failure or through theft, and make reasonable effort to ensure that personal records so lost are not used wrongfully.
28. A Payment Service Provider shall develop a business continuity plan based on the business impact analysis and related recovery strategies. A business continuity plan shall comprise, at a minimum:
- 28.1. detailed recovery procedures to ensure full accomplishment of the service recovery strategies;
 - 28.2. escalation procedures and crisis management protocol (e.g. set up of a command center, timely reporting to the Central Bank, etc.) in case of severe or prolonged service disruptions;
 - 28.3. proactive communication strategies (e.g. Retail Payment Service User notification, media response, etc.);
 - 28.4. updated contact details of key personnel involved in the business continuity plan; and
 - 28.5. assignment of primary and alternate personnel responsible for recovery of critical systems.
29. A Payment Service Provider shall conduct testing of its business continuity plan at least annually. Its Management, primary and alternate relevant personnel shall participate in the

annual testing to familiarize themselves with their recovery responsibilities.

30. A Payment Service Provider shall review all business continuity planning-related risks and assumptions for relevancy and appropriateness as part of the annual planning of testing. Formal testing documentation, including a test plan, scenarios, procedures and results, shall be produced. A post mortem review report shall be prepared for formal sign-off by Management

Alternate Sites for Business and IT Recovery

31. A Payment Service Provider shall examine the extent to which key business functions are concentrated in the same or adjacent locations and the proximity of the alternate sites to primary sites. Alternate sites shall be sufficiently distanced to avoid any shared risk and being affected by the same disaster.
32. A Payment Service Provider's alternate site shall be readily accessible, installed with appropriate facilities and available for occupancy within the time requirement specified in its business continuity plan. Appropriate physical access controls shall be implemented. If certain recovery staff are required to work from home in the event of a disaster, adequate computer systems and communication facilities shall be made available in advance.
33. Alternate sites for IT recovery shall have sufficient technical equipment, including communication facilities, of an appropriate standard and capacity to meet recovery requirements.
34. A Payment Service Provider shall avoid placing excessive reliance on external vendors in providing business continuity management support, including the provision of the disaster recovery site and back-up equipment and facilities. A Payment Service Provider shall satisfy itself that each vendor has the capacity to provide the services when needed, and that the contractual responsibilities of the vendors, including the lead-time to provide necessary emergency services, types of support and capacity, are clearly specified.
35. Where a Payment Service Provider is reliant on shared computing services provided by external providers, such as cloud computing, to support its disaster recovery, it shall manage the risk associated with these services.

Reputation Risk Management

36. A Payment Service Provider shall establish and implement an effective process for managing reputational risk that is appropriate for the size and complexity of its operations.